

108 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：108 年 12 月 07 日

第 1 頁，共 9 頁

單選題 50 題 (佔 100%)

A	1. 關於搜尋引擎攻擊 (Google-hacking)，主要在破壞資訊系統的何種特性？ (A)機密性 (Confidentiality) (B)完整性 (Integrity) (C)可用性 (Availability) (D)責任性 (Accountability)
B	2. 請問「對資料修改權的約束與限制，只有擁有權限的使用者才能修改」所代表的意義是下列何者？ (A)機密性 (Confidentiality) (B)完整性 (Integrity) (C)可用性 (Availability) (D)可讀性 (Readability)
C	3. 關於將資料設定為「唯讀」之目的，下列敘述何者正確？ (A)是為了確保資料之機密性 (B)是為了確保資料之可用性 (C)是為了確保資料之完整性 (D)是為了確保資料之可讀性
C	4. 當進行風險評估，發現機密資料外洩風險是組織內部最大之風險時，組織進行了相對應之風險處理方法，其中包含了購買資料外洩保險，此為下列何種風險處理方式？ (A)風險接受 (B)風險降低 (C)風險轉移 (D)風險避免
C	5. 建立或導入資訊安全管理系統 (Information Security Management System, ISMS) 時，最重要的第一個步驟是下列何者？ (A)資訊資產分級與盤點造冊 (B)資訊安全教育訓練 (C)界定資訊安全管理系統的範圍 (D)實施必要的控制措施
A	6. 關於資訊安全管理系統 (Information Security Management System, ISMS) 中的實體控制措施，下列敘述何者「不」正確？ (A)設立訪客櫃台，為了表示友善，訪客可以自由進出辦公區域 (B)劃分安全區域，設定門禁管理

108 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：108 年 12 月 07 日

第 2 頁，共 9 頁

	(C) 進出機房重地除了需刷卡外，還需要留下詳細的進出記錄 (D) 沒有被授權的人員，不應該進入管制區域
B	7. 導入資訊安全管理系統 (Information Security Management System, ISMS)，第三方驗證單位是依據下列何種 ISO 標準進行驗證？ (A) ISO/IEC 27000 :2013 (B) ISO/IEC 27001 :2013 (C) ISO/IEC 27002 :2013 (D) ISO/IEC 27003 :2013
C	8. 可建議發出 ISO 27001 通過驗證的國際證書，為下列何者？ (A) 第一方稽核 (B) 第二方稽核 (C) 第三方稽核 (D) 第四方稽核
C	9. 權責單位應該定期與不定期進行資訊資產盤點與異動檢核，以確保資訊資產的更新，下列何種情況「不」需要進行資訊資產的異動檢核？ (A) 資訊資產新增、變更或移除 (B) 作業環境變更 (C) 公司舉辦法人說明會 (D) 系統有重大異動
C	10. 在進行資產分級評估時，如果資訊系統服務中斷，將造成組織營運出現重大影響，此狀況屬於下列何種評估面向？ (A) 機密性 (B) 完整性 (C) 可用性 (D) 流動性
B	11. 下列何種人員主要負責資訊 (Information) 的保護與維護？ (A) 所有者 (Owner) (B) 保管員 (Custodian) (C) 資訊安全經理 (Information Security Manager) (D) 資訊風險經理 (Information Risk Manager)
D	12. 在公司資產管理中，為達成識別組織之資產並定義適切之保護責任，應優先建議採取下列何種控制措施？ (A) 金鑰管理 (B) 懲處過程

108 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：108 年 12 月 07 日

第 3 頁，共 9 頁

	(C)變更管理 (D)資產清冊
A	13. 下列何者為資訊分級的主要目標？ (A)確保資訊依其對組織的重要性，受到適切等級的保護 (B)確保與資訊有關的資產，已被正確的識別和記錄 (C)確保與資訊有關的資產，已被正確的盤點和造冊 (D)確保資訊資產於員工離職時，已經完整的歸還
D	14. 下列何者屬於組織的無形資產？ (A)機房 (B)委外廠商 (C)員工 (D)商譽
B	15. 關於資訊資產分級，下列敘述何者較「不」正確？ (A)資訊資產的分級基準依組織的屬性而有不同 (B)價格愈高的資訊資產其資產價值愈高 (C)該資產所支援流程的重要性與資產等級有關 (D)組織內不可能所有資產的重要性都一樣
A	16. 在風險評鑑的過程，對於衝擊所造成的損失，不以金錢來計算，而改採用「極小、較小、中等、較大、巨大」的方式來表達，屬於下列何種方法？ (A)定性法 (B)類比法 (C)定量法 (D)參數法
C	17. 執行定期風險評鑑進入尾聲時，發現一項新的風險議題，下列何者較「不」適當？ (A)將該風險議題納入此次風險評鑑，一併完成評鑑 (B)針對該風險議題額外執行風險評鑑並出具報告 (C)因定期風險評鑑有完成期限，故對此風險議題不做處理 (D)先初步評估該風險議題是否有重大影響，若無重大影響則於事後再進行完整評估
D	18. 關於風險評估（Risk Evaluation），下列敘述何者正確？ (A)是識別風險來源、事件、發生的原因，與可能產生的後果 (B)是組織進行風險評鑑、識別、分析的整體流程

108 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：108 年 12 月 07 日

第 4 頁，共 9 頁

	(C)是理解風險本質並且決定風險等級的流程 (D)是比較風險分析結果與風險準則來決定風險或嚴重程度是否為可接受的流程
D	19. 下列何者「不」是選擇風險處理對策時的主要考量因素？ (A)法令法規 (B)實施成本 (C)利害相關者的感知 (D)短期內可達成
C	20. 下列何者「不」是風險處理的選項？ (A)風險降低 (B)風險轉移 (C)風險忽略 (D)風險接受
A	21. 使用者身分識別大致可分所知之事（something you know）、所持之物（something you have）及生物特徵（something you are），下列何者「不」是所持之物（something you have）識別？ (A)用指紋開電腦 (B)刷卡進機房 (C)用提款卡領錢 (D)用鑰匙開門
B	22. 勒索病毒（Ransomware）使用對稱式加密技術與非對稱式加密技術來進行加密電腦內的檔案，讓使用者無法使用，此現象主要影響資訊系統的何種特性？ (A)機密性（Confidentiality） (B)可用性（Availability） (C)完整性（Integrity） (D)鑑別性（Authenticity）
B	23. 若公司的門禁出入管制已使用生理特徵認證（Biometric Authentication）設備進行身分驗證，為更加嚴格管制，建議應如何調整生理特徵設備？ (A)選擇交叉錯誤率（Crossover Error Rate, CER） (B)提高錯誤拒絕率（False Rejection Rate, FRR） (C)提高錯誤接受率（False Acceptance Rate, FAR） (D)選擇相等錯誤率（Equal Error Rate, EER）
A	24. 公司規定系統權限異動應書面申請，並經主管核准方可執行，下列何項

108 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：108 年 12 月 07 日

第 5 頁，共 9 頁

	申請「不」宜開放權限？ (A)採購人員申請單據刪除權限經財會主管核准 (B)資訊主管申請管理者權限經總經理核准 (C)財會人員申請系統月結權限經財會主管核准 (D)稽核主管申請系統所有模組的查詢權限經董事長核准
B	25. 關於存取控制，下列敘述何者較「不」適當？ (A)使用防火牆區隔內外網路，將公司對外全球網站放置於 DMZ 區 (Demilitarized zone)，並關閉非必要的連接埠 (B)使用網段區隔技術，隔離敏感系統、重要機密的工作群組以及各類別的職務群組，但為了通聯及工作的便利性，內部網路各網段應直接互相通聯 (C)機密檔案加密系統的使用者依不同的工作性質設定群組權限，非該群組成員無法開啟其加密檔案 (D)重要系統設定其使用者超過一段時間未動作即會自動登出
A	26. 若想採用暴力攻擊的方式破解以小寫英文和數字所組成的八位密碼，至多總共要嘗試多少次？ (A) $(26+10)^8$ (B) 26^8+10^8 (C) $(10+26) \times 8$ (D) $C_8^{(10+26)}$
C	27. 制定組織內部存取控制政策時，下列何種考量項目較為適合？ (A)對需要的使用者皆開放所需要的權限 (B)配置存取權限時可以有共用帳號的使用 (C)組織營運應用之安全要求事項需納入 (D)對於存取權限的配置過程不需留下正式授權核可的紀錄
A	28. 下列何種管控技術較「不」適合用來作為身分認證使用？ (A)SNMP (Simple Network Management Protocol) (B)RADIUS (Remote Authentication Dial In User Service) (C)LDAP (Lightweight Directory Access Protocol) (D)TACACS (Terminal Access Controller Access-Control System)
D	29. 透過 ID 與密碼登入系統時，所使用的 ID 目的為下列何者？ (A)認證 (B)授權 (C)負責

108 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：108 年 12 月 07 日

第 6 頁，共 9 頁

	(D)識別
D	30. 憑證記載了個人資料、公開金鑰、憑證單位名稱、數位簽章、以及憑證有效期限及用途等資訊，下列何者「不」是它的特性？ (A)完整性（Integrity） (B)不可否認性（Non-Repudiation） (C)身分識別（Authentication） (D)可用性（Availability）
B	31. 關於智慧卡（Smart Card），下列敘述何者較「不」正確？ (A) 智慧卡可攜帶方便 (B) 智慧卡不會遭到實體攻擊 (C) 智慧卡可以儲存人腦無法記憶的密碼長度 (D) 大部分智慧卡都設計三次 PIN 輸入錯誤就會卡片鎖死
C	32. 遠端用戶撥入驗證服務（Remote Authentication Dial In User Service , RADIUS）是 AAA 三種服務的網絡傳輸協議，關於此 AAA，下列何者「不」正確？ (A) Authentication (B) Authorization (C) Access (D) Accounting
B	33. 下列何種技術最常被拿來作為檔案完整性（Integrity）的檢查使用？ (A) ECC (B) MD5 (C) RSA (D) AES
B	34. 關於古典密碼學技術與現代密碼學技術，下列敘述何者較「不」正確？ (A) 凱薩（Caesar）演算法為早期的古典密碼學技術 (B) 現代密碼學的加密演算法不可公開 (C) AES 加密演算法屬於現代密碼學技術 (D) 柵欄（Rail Fence）演算法在古典密碼學技術就出現
D	35. 下列何種機制「不」可用於加密及解密？ (A) AES（Advanced Encryption Standard） (B) DES（Data Encryption Standard） (C) RSA（Rivest-Shamir-Adleman） (D) MD5（Message-Digest Algorithm）

108 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：108 年 12 月 07 日

第 7 頁，共 9 頁

A	36. 依據國家資通安全通報應變作業中所訂定的資安事件影響等級，共分為幾種等級？ (A) 4 級 (B) 5 級 (C) 3 級 (D) 7 級
D	37. 關於企業組織遭遇 DoS 或 DDoS 攻擊的常見特徵，下列敘述何者「不」正確？ (A) 網路頻寬滿載 (B) 網通設備或防火牆不堪負載 (C) 電腦與伺服器作業系統或服務超載 (D) 網站內容只有影片無法播放
A	38. 重大資安事故通常會分析其根本原因 (Root Cause)，最主要目的在於下列何者？ (A) 找出避免相同事故再次發生之處置方法 (B) 懲處相關人員 (C) 可能需要進行數位鑑識 (Forensic) (D) 縮短當下的應變時間
A	39. 證據保管鏈 (Chain of Custody) 為具有保管且能夠為證據提供文件證明的程序，紀錄中應該有資料蒐集的人、時、地、保管人以及對證據的保護手法，可用下列何種方式確保證據記載之資訊的完整性？ (A) SHA-256 (B) X.509 (C) WPA2 (D) TLS 1.3
B	40. 關於營運衝擊分析應考慮項目，下列敘述何者「不」正確？ (A) 復原至最低營運程度所需之員工、技能、設施及服務所需之時間 (B) 損害程度之等級不包括收入損失、附加成本、商譽損失、喪失競爭優勢等 (C) 最低營運程度所需之員工、技能、設施及服務 (D) 完全復原至原服務水準所需之員工、技能、設施及服務所需之時間
B	41. 公司在分析重要營運功能的損壞或失去所造成的損害程度行為，稱為下列何者？ (A) 風險評鑑 (Risk Assessment)

108 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：108 年 12 月 07 日

第 8 頁，共 9 頁

	(B) 營運衝擊分析 (Business Impact Analysis) (C) 危機溝通計畫 (Crisis Communications Plan) (D) 風險評估 (Risk Evaluation)
A	42. 在進行營運持續規劃時，若評估發現公司資料遺失之最大可接受程度為 10 分鐘內，應考慮下列何者？ (A) 恢復點目標 (Recovery Point Objective, RPO) (B) 恢復時間目標 (Recovery Time Objective, RTO) (C) 工作恢復時間 (Work Recovery Time, WRT) (D) 最大可容忍中斷時間 (Maximum Tolerable Period of Disruption, MTPD)
B	43. 若固定每星期日執行一次完整備份 (Full Backup)，星期一到星期六每天備份與前一天差異的部分 (如：星期一備份與星期日的差異，星期三備份與星期二的差異)，此現象稱為下列何者？ (A) 差異備份 (Differential Backup) (B) 增量備份 (Incremental Backup) (C) 循環備份 (Circulatory Backup) (D) 緊急備份 (Emergency Backup)
B	44. 下列何種磁碟陣列 (RAID) 等級，沒有提供容錯能力？ (A) RAID 1 (B) RAID 0 (C) RAID10 (D) RAID 5
D	45. 在進行演練測試時，規劃將關閉主站點來進行有效測試，請問此方法為下列何種測試？ (A) 結構化瀏覽演練 (Structured Walk-through) (B) 模擬測試 (Simulation Test) (C) 並行測試 (Parallel Test) (D) 完全中斷測試 (Full-interruption Test)
C	46. 個人資料保護法之立法目的有二：一是避免人格權受侵害、一是促進個人資料合理利用，下列何種資訊「不」屬於個資法保護的個人資料？ (A) 自然人之姓名、出生年月日 (B) 國民身分證統一編號、護照號碼 (C) 公司電子信箱、員工編號 (D) 特徵、指紋

108 年度初級資訊安全工程師能力鑑定試題

科目 1：資訊安全管理概論

考試日期：108 年 12 月 07 日

第 9 頁，共 9 頁

D	47. 在學校宿舍內架設網站，分享從網路上下載的音樂或影片，並且提供同學下載，請問侵犯了智慧財產權相關法規的哪一條？ (A)營業秘密法 (B)商標法 (C)個人資料保護法 (D)著作權法
D	48. 下列何者「不」是隱私保護與智慧財產權需遵守的項目？ (A)制定智慧財產權遵循政策，並定義軟體及資訊產品之合法使用 (B)維護與實作使用授權、原版光碟及手冊等之所有權的證明文件 (C)所有員工皆須遵循有關客戶資訊隱私保護之相關法律及法規 (D)員工可識別資訊不在隱私保護要求範圍內
A	49. 為保障持卡人的資料安全，制定統一的資料安全標準，提供資料安全的技術與作業要求之基準，此行為屬下列何者？ (A)PCI DSS (B)HIPAA (C)Sarbanes-Oxley Act (D)Basel II
C	50. 下列何者違反 GDPR (General Data Protection Regulation) 的規範要求？ (A)GDPR 為歐盟一般資料保護法規 (B)任何使用與歐盟公民相關資訊的公司都必須遵循 (C)雲端處理者與控制者目前不納入 GDPR 強制實施範圍 (D)要求持有個人可識別資訊的組織，需實施適切的安全控制措施，以防止個人資料遺失